NoteMD — penetration test handover pack

21 October 2026 · release candidate for independent assurance

Everything a tester needs to scope and begin, plus an honest account of what has already been tested and what has not. Where a control exists, this says where it is enforced — so a tester can go straight to confirming it rather than discovering it.

---

1. What the system is

A clinical documentation tool for UK clinicians. Audio from a consultation or dictation is transcribed, a letter is generated from the transcript, the clinician reviews and edits it, and may email it.

The data is special category health data about identifiable patients. A successful attack is not inconvenient; it is a notifiable incident.

Frontend	React 18 / TypeScript SPA, static bundle, no server-side rendering
Backend	Supabase Edge Functions (Deno), 13 functions
Database	Supabase PostgreSQL 15, `eu-west-1`
Auth	Supabase Auth (GoTrue), JWT, optional TOTP second factor
Object storage	Supabase Storage, two private buckets

---

2. Scope

In scope

TARGET	NOTES
`https://notemd.co.uk`	Production frontend. **Test against staging unless agreed otherwise** — see §7
`https://<ref>.supabase.co/functions/v1/*`	13 edge functions, listed in §4
`https://<ref>.supabase.co/rest/v1/*`	PostgREST, governed by row-level security
Supabase Auth endpoints	Sign-in, registration, password reset, MFA enrolment and challenge
Supabase Storage	Buckets `audio-recordings` and `context-documents`

Out of scope

- **Third-party provider infrastructure** — AssemblyAI, Deepgram, Azure OpenAI, Azure Communication Services, Stripe. Test our use of them, not them.
- **Supabase and Render platform internals.** Platform vulnerabilities go to those vendors.
- **Denial of service.** Rate limiting exists and its limits are documented in §5; demonstrating that a limit can be reached is useful, exhausting the account is not.
- **Social engineering of the client or their clinicians.**

---

3. Authentication and authorisation model

This is where the interesting findings will be, so it is described in detail.

Identity. Supabase Auth issues a JWT carrying `sub` (user id). Every security decision keys on `auth.uid()` derived from that token. There is no separate session store and no server-side session state.

Roles. `profiles.role` is one of `clinician`, `admin`, `doctor`, `secretary`.

A secretary acts on behalf of a clinician through `profiles.clinician_id`. **That relationship is the most interesting authorisation surface in the system** — it is the one place where a user legitimately reaches data owned by a different user id.

Role escalation was deliberately closed. Clinicians can update their own profile row, which once allowed an account to set its own `role` to `admin` or reassign `clinician_id`. A trigger now rejects changes to the privileged columns unless made with the service role — see `20260917100000_lock_privileged_profile_columns.sql`. **Worth attacking directly.**

Second factor. TOTP, optional per account. Enforcement is in `ProtectedRoute`: it reads the authenticator assurance level and blocks when `nextLevel` is `aal2` and `currentLevel` is not. The gap this closes is a user who has enrolled a factor but holds an `aal1` session. **A tester should check whether an `aal1` token can reach the REST API and the edge functions directly, bypassing the frontend check** — the frontend cannot be the control and is not claimed to be.

Password reset is GoTrue's flow. Requests and completions are recorded in the audit trail (`auth.password_reset_requested`, `auth.password_changed`).

---

4. Edge functions

All require a bearer token except where noted. Each authenticates, then rate limits, then works.

FUNCTION	GATEWAY JWT	NOTES FOR THE TESTER
`streaming-session`	enforced	Issues a short-lived vendor credential and a complete endpoint URL. Try to obtain a session for a different user, or to influence the vendor/region
`transcribe-audio`	enforced	Takes a storage path. **Try paths belonging to another user**
`generate-letter`	**disabled at gateway**	Authenticates internally. Was `verify_jwt = false` for a historical reason; confirm the internal check cannot be bypassed
`regenerate-letter`	enforced	
`summarise-context`	enforced	Takes `context_id`. Reads through the caller's own client so RLS applies — confirm
`send-letter-email`	enforced	**Refuses a letter not marked reviewed (HTTP 409).** Try to send an unreviewed letter, or one belonging to another user
`send-transcript-email`	enforced	As above
`manage-secretary`	enforced	Uses the service role to assign roles. **Highest-value target in the set**
`diagnostics-transcription`	enforced	**Administrators only**, checked server-side before any vendor is probed
`deepgram-token`	enforced	**Superseded by `streaming-session`; scheduled for removal.** Still deployed — confirm it is not a way to obtain a long-lived vendor key
`create-checkout-session`, `create-portal-session`	enforced	Billing
`stripe-webhook`	**disabled at gateway**	Authenticates by verifying `Stripe-Signature` against the webhook secret. **Try forging an event**

5. Controls already implemented

Stated so a tester can confirm or break them rather than rediscover them.

CONTROL	WHERE ENFORCED
Row-level security on every table holding clinical data	PostgreSQL policies
Storage objects owner-scoped by first path segment	Storage policies, both buckets
Rate limiting on endpoints that cost money or send mail	`check_rate_limit()`, counters in Postgres, subject is always `auth.uid()` and never a parameter
Privileged profile columns locked against self-assignment	Database trigger
Email refused on an unreviewed letter	`send-letter-email`, HTTP 409, audited as denied
Direct identifiers withheld from the AI provider	NHS number tokenised; see §8
Security headers incl. a strict CSP	Render response headers, verified in production
EU-only vendor endpoints enforced in the browser	CSP `connect-src` names each vendor's EU host and omits their global ones
Inactivity timeout, configurable per clinician	Frontend timer plus session expiry
Audit trail	38 distinct actions, server and client side

Rate limits (per user, per hour)

`transcribe-audio` 1500 · `deepgram-token` 120 · `generate-letter` 60 · `regenerate-letter` 90 · `send-letter-email` 60 · `send-transcript-email` 60 · `summarise-context` 40 · `manage-secretary` 20

The limiter fails open. If the counter cannot be read or written the request proceeds. That is deliberate — a database hiccup refusing to transcribe a consultation in progress is worse than an unbounded window during an incident — but it is a design decision a tester should know about and may wish to challenge.

---

6. What has already been tested, and how

Automated: **510 tests**, run on every change.

AREA	COVERAGE
Cross-user access (IDOR)	26 integration tests against a live staging database, exercising real tokens for two users across every table and both storage buckets
Wrong-patient association	Session-token guard on every path by which transcribed text reaches a transcript
Log hygiene	Regression tests asserting that patient data never reaches logs
Data minimisation	Asserts the NHS number never reaches the AI provider's request
Security headers	Verified against the live site, not only the configuration file
Residency	Verified from each provider's own response headers, and the CSP enforcement confirmed in the browser
Backup and recovery	Documented restore test

The IDOR suite is skipped by default and runs against staging with real credentials. A tester may want to read it first: `src/test/idor.integration.test.ts`.

What has NOT been tested, and should be

Stated plainly, because a handover that implies complete coverage is worse than useless:

1. **No independent security testing has ever been performed.** All of the above is self-assessment by the developer who wrote the code.
2. **No authenticated automated scanning** has been run against the application.
3. **The `aal1` bypass described in §3** has been reasoned about but not attacked.
4. **`generate-letter` and `stripe-webhook` run with the gateway JWT check disabled.** Both authenticate internally. Neither has been independently probed.
5. **Business logic around the secretary relationship** has unit coverage but has not been adversarially explored.
6. **File upload handling** for context documents is new (October 2026). PDFs are parsed in the browser; malformed and malicious files have been handled for robustness but not for exploitation.
7. **No load or abuse testing** beyond the rate limits existing.

---

7. Environments and test data

Test against staging. It is a separate Supabase project with its own database, storage and credentials, holding synthetic data only. Production holds real patient data and testing against it would itself be an incident.

Local development and `npm run dev` point at staging by design, so the default target for any tooling is already the right one.

The application displays a banner in any non-production environment, so a tester can always see which they are on.

Credentials: test accounts for a clinician, a secretary linked to that clinician, and an administrator should be issued by NoteMD before testing begins. A second unrelated clinician account is needed for cross-user work.

---

8. Deliberate design decisions a tester may question

Listed so they are discussed rather than reported as findings without context.

The patient's name is sent to the AI provider; the NHS number is not. The name was previously tokenised, but clinicians say it aloud and transcription rendered it phonetically, so a misspelling reached the letter anyway — the minimisation was not achieving what it claimed, and cost correctness. The NHS number is still withheld. See `evidence/data-minimisation.md`.

Audio streams from the browser directly to the transcription vendor, not through our servers. This means the vendor sees the audio and our infrastructure does not proxy it. The CSP constrains where it can go.

The rate limiter fails open. See §5.

`generate-letter` has the gateway JWT check disabled. It authenticates internally. This is recorded in `supabase/config.toml` with its reason, after a full deploy once silently re-enabled it and broke billing.

Uploaded context documents are summarised by an AI model, and that summary informs the letter **only** if the clinician explicitly opts in — off by default, and recorded per letter.

---

9. Evidence index

DOCUMENT	CONTENTS
`TECHNICAL-ARCHITECTURE.md`	Full technical review, data flows, residency
`GDPR-PROCESSOR-PACK.md`	Sub-processor register, records of processing
`GDPR-STATUS.md`	Compliance position and remaining gaps
`evidence/idor-results.md`	Cross-user access testing
`evidence/security-headers.md`	Headers and CSP, verified in production
`evidence/assemblyai-residency.md`	Live transcription residency and controls
`evidence/azure-openai-cutover.md`	Azure migration and verification
`evidence/consultation-context.md`	Document upload, OCR, retention, letter opt-in
`evidence/data-minimisation.md`	What reaches each provider
`evidence/wrong-patient-concurrency.md`	Session-token guard
`evidence/log-hygiene.md`, `evidence/log-redaction-regression.md`	Logging
`evidence/backup-configuration.md`, `evidence/recovery-test.md`	Backup and restore
`evidence/production-access.md`	Who has administrative access
`evidence/email-delivery.md`	Email authentication and delivery

10. Contact and disclosure

Findings to NoteMD, who will route them to the development team. **Any finding that could expose patient data should be reported immediately rather than held for the final report**, and NoteMD must consider its own breach-notification obligations as controller.